



Base de una estrategia de seguridad es el Sistema de Gestión de la Seguridad de la Información (SGSI), regido por la familia ISO 27000.

Políticas y Estandarización



Índice

Introducción	2
El Sistema de Gestión de la Seguridad de la Información (SGSI)	2
La Familia de Estándares ISO 27000	2
El Ciclo de Vida Continuo: PDCA y Medición (ISO 27004)	3
Análisis de Riesgos: El Punto de Partida (ISO 27005)	5
Implementación de Controles y Bastionado (Guías CIS)	6
El SGSI en Operación: Procesos y Gobernanza	8
El SGSI como Requisito de Resiliencia	9

Introducción

El concepto de seguridad ha evolucionado a lo largo de las décadas. Inicialmente, se enfocaba en la seguridad informática (protección de sistemas tecnológicos). Posteriormente, se transformó en seguridad de la información, centrada en proteger la información almacenada en dichos sistemas. Más recientemente, el término ha escalado a ciberseguridad, cuyo objetivo es proteger no solo la información, sino también la infraestructura tecnológica que la soporta y que es vital para el funcionamiento de la sociedad.

La información es el activo más importante de cualquier organización. Por lo tanto, cualquier estrategia defensiva debe basarse en proteger la información y los servicios que esta presta, y no solo las infraestructuras que la contienen.

El Sistema de Gestión de la Seguridad de la Información (SGSI)

El SGSI (o ISMS en inglés) es la estructura que permite a una organización gestionar su seguridad de manera metódica y continua.

El SGSI es una parte de los sistemas de la empresa, cuya finalidad principal es establecer, implementar, operar, monitorizar, revisar, mantener y mejorar la seguridad de la información, basándose en el análisis de riesgo de negocio. Para que un SGSI funcione adecuadamente, debe contar con información documentada sólida, lo cual es uno de sus pilares básicos.

La adopción del SGSI es una decisión estratégica de la organización, influenciada por los objetivos del negocio, los requerimientos de seguridad y la estructura de la empresa.

La Familia de Estándares ISO 27000

La familia de estándares ISO/IEC 27000 forma un conjunto de normas internacionales cuyo objetivo es normalizar las técnicas, actividades y medidas a considerar para la implantación de un SGSI. Este marco es fundamental para la seguridad de los sistemas de información en el siglo XXI.

El estándar clave y certificable de esta familia es la ISO/IEC 27001:2017. La ISO 27001 no está orientada a despliegues tecnológicos, sino a aspectos organizativos, buscando "Organizar la

seguridad de la información". El cuerpo principal de la norma se centra en tres grandes líneas de trabajo:

1. SGSI (Sistema de Gestión de Seguridad de la Información)
2. Valoración de Riesgos (Risk Assessment)
3. Controles (Anexo A)

Es crucial destacar que la norma ISO 27001 exige la participación y el compromiso de la Alta Dirección en el SGSI.

El Ciclo de Vida Continuo: PDCA y Medición (ISO 27004)

El Modelo Plan-Do-Check-Act (PDCA)

La seguridad no debe ser un hito estático, sino un ciclo de vida continuo que debe mantenerse y mejorarse. La experiencia demuestra que la ciberseguridad en el siglo XXI sufre una degradación abismal si no se mantiene. La ISO 27001 adopta el famoso ciclo de Deming o PDCA (Plan-Do-Check-Act):



Fase	Descripción	Responsabilidad
Plan	Establecer el SGSI: Definir la política, los objetivos, los procesos y los procedimientos relevantes para la administración de riesgos, conforme a los objetivos de la organización.	Nivel Estratégico/Gerencial
Do	Implementar y operar el SGSI: Ejecutar la política, los controles, los procesos y los procedimientos definidos en la fase de Planificación.	Nivel Operacional/Ejecutor
Check	Monitorizar y revisar el SGSI: Analizar y medir los procesos ejecutados y evaluar los objetivos (auditorías internas), informando los resultados a la dirección.	Nivel Táctico (Gobierno de la Seguridad)
Act	Mantener y mejorar el SGSI: Realizar las acciones correctivas y preventivas, basadas en los resultados de las auditorías y revisiones, para permitir la continua mejora del SGSI .	Nivel Táctico (Gobierno de la Seguridad)



El Gobierno de la Seguridad y la Medición (ISO 27004))

La actividad de **Gobierno de la Seguridad** es responsable de mantener "vivo" el estado de seguridad, auditando y diseñando las acciones de mejora necesarias. Esta función se sustenta en la capacidad de medir el desempeño del SGSI.

La norma **ISO/IEC 27004** (Tecnología de la Información - Medición) es fundamental en este ciclo. La ISO 27001 enfatiza que si un **Control no se puede medir, "no sirve para nada"**. La ISO 27004 guía cómo deben medirse estos controles, procesos y la eficiencia del SGSI.

La medición se orienta principalmente a la fase "Do" (Implementación), sirviendo como entrada para la fase "Check" (Monitorización y revisión), permitiendo así adoptar decisiones de mejora en la fase "Act".

Las mediciones (Métricas) deben ser **relevantes**, reflejando la prioridad de la información que se necesita, y deben estar documentadas con su propósito, método de medición, escala y frecuencia. El objetivo último es generar un **"Cuadro de Mando"** que ofrezca la información necesaria a cada nivel jerárquico de la empresa para la toma de decisiones.

Análisis de Riesgos: El Punto de Partida (ISO 27005)

El Análisis de Riesgos (Risk Analysis) es la actividad inicial y más importante de todo SGSI. El SGSI se basa en el análisis de riesgo de negocio.

El SGSI debe iniciarse con la identificación de los activos críticos. Según la metodología española MAGERIT, los activos esenciales de un sistema de información son dos: la información que se maneja y los servicios que se prestan.

La ISO/IEC 27005 proporciona las directivas para la gestión de riesgos de seguridad de la información. Este proceso incluye la identificación, análisis, estimación y evaluación de los riesgos, y el desarrollo de un plan de tratamiento del riesgo:

Metodologías de Análisis de Riesgos (MAGERIT)

Aunque la ISO 27001 no exige una metodología de análisis de riesgos específica, sí requiere que la actividad sea coherente y metodológica.

La metodología MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información), elaborada por el Consejo Superior de Administración Electrónica del Gobierno de España, es una referencia clave. MAGERIT se estructura en tareas como:

1. Caracterización de los activos (Identificación, Dependencias y Valoración).
2. Caracterización de las amenazas (Identificación y Valoración).
3. Caracterización de las salvaguardas (Identificación de las salvaguardas pertinentes).
4. Tratamiento y Gestión de Riesgos.

El proceso de análisis de riesgos debe ser un ejercicio formal que esté bajo monitorización permanente.

El Tratamiento del Riesgo y la Decisión de la Dirección:

El análisis de riesgos desemboca en la estimación de qué medidas de seguridad (salvaguardas o controles) son necesarias para mitigar el riesgo. Es importante recordar que el riesgo nunca desaparece, por lo que el SGSI debe plantear diferentes cursos de acción para la mitigación.

La Alta Dirección es quien debe tomar la decisión final (la Aceptación de Riesgo). La ISO 27001 es clara: si el conjunto de medidas es muy costoso, la empresa puede decidir una planificación progresiva e incluso "Asumir el riesgo". El gran acierto de la norma es que la dirección debe adoptar su "Curso de Acción" y firmarlo, asumiendo así la responsabilidad del riesgo.

Implementación de Controles y Bastionado (Guías CIS)

Los Controles del SGSI (ISO 27001/27002)

Una vez que la Dirección ha adoptado un curso de acción, la siguiente fase del SGSI es la aplicación de Controles. Los controles son seleccionados e implementados de acuerdo con los requerimientos identificados por el análisis de riesgos.

- Controles Mínimos: El Anexo A de la ISO 27001 proporciona un listado de 133 controles mínimos agrupados en 11 dominios.
- Detalle del Control: La norma ISO/IEC 27002 es la que describe con máximo detalle cada uno de estos controles y objetivos.
- Declaración de Aplicabilidad (SoA): Las organizaciones deben elaborar la Declaración de Aplicabilidad (Statement of Applicability), un documento clave que describe los objetivos de control y los controles que son relevantes y aplicables al SGSI de la organización, justificando la exclusión de cualquier control que no aplique.

Si el análisis de riesgos determina la necesidad de nuevos controles no listados en el Anexo A de la ISO 27001, estos deben ser incluidos en la implantación del SGSI para evitar "huecos" o brechas claramente identificables

Bastionado Técnico y las Guías CIS

La implementación técnica de los controles en los dispositivos de red y sistemas operativos se conoce como hardening o bastionado.

El mayor referente que debe tenerse en cuenta para el bastionado de dispositivos (incluyendo switches, routers, sistemas operativos, y plataformas) se encuentra en las Guías CIS (Center for Internet Security). Las guías CIS son fundamentales para descargar documentos de bastionado y son un pilar a considerar en la seguridad.

El trabajo de bastionado implica comprender y analizar las configuraciones de los dispositivos, que generalmente se realizan a través de ficheros de texto plano. Este análisis debe ser periódico y basarse en un ciclo de mejora continua (PDCA), ya que la seguridad se degrada con el tiempo

Ejemplos de Controles Técnicos (Hardening):

La aplicación de las guías CIS conduce a medidas técnicas esenciales:

- **Inhabilitación de protocolos inseguros:** Es imprescindible deshabilitar protocolos que envían información en texto plano. Ejemplos son Telnet y FTP, ya que exponen comandos y contraseñas.
- **Cifrado y Seguridad de Acceso:** Se recomienda el uso de SSH versión 2 en lugar de la versión 1, ya que la V2 separa los protocolos de autenticación y conexión y utiliza algoritmos robustos de integridad criptográfica. Para la gestión, es vital contar con algún tipo de servidor RADIUS o TACACS para validar usuarios y almacenar registros de actividad.
- **Gestión de Puertos:** Una medida mínima de seguridad imprescindible es cerrar los puertos/bocas no empleados en dispositivos como los switches.
- **Evaluación de Credenciales:** Las auditorías deben incluir la verificación de la fortaleza de las contraseñas de la infraestructura, utilizando herramientas como John the Ripper o Medusa/Hydra contra protocolos de aplicación (telnet, ftp, snmp, http, pop3) para comprobar la robustez de la red frente a ataques de fuerza bruta o diccionario

El SGSI en Operación: Procesos y Gobernanza

La Dirección y Gestión de la Documentación

La Información documentada es la columna vertebral del SGSI. La ISO 27001 establece que el SGSI debe incluir la información documentada necesaria para su eficacia.

La documentación debe organizarse en una jerarquía documental que generalmente consta de al menos tres niveles: Política de Seguridad (nivel estratégico), Procesos/Procedimientos (nivel táctico, con detalle de las acciones), y Manuales/Guías Técnicas (nivel operativo).

La gestión documental es esencial para controlar: el almacenamiento, la recuperación, la clasificación, la seguridad, la custodia y la autenticación. El control de documentos requiere procedimientos para su aprobación, revisión, actualización e identificación de la última versión disponible

Procesos Operacionales Clave dentro del SGSI

El Planeamiento de la seguridad (parte del SGSI) debe diseñar la implementación de las medidas para mitigar los riesgos definidos por el nivel Estratégico. Esto se logra a través de robustos procesos de seguridad que mantienen "viva" la seguridad.

Entre los procesos básicos que cobran una importancia fundamental en ciberseguridad se encuentran:

- **Gestión de Logs:** La centralización de Logs es crítica. Plataformas SIEM (Security Information and Event Management), como ArcSight, RSA Security Analytics o Splunk, son esenciales para centralizar y correlacionar eventos de seguridad. Un intruso intentará borrar sus huellas; si los Logs se envían a un servidor externo (SIEM), el atacante debe comprometer también ese servidor para eliminarlos.
- **Gestión de Backup:** El backup es la última medida que se tiene para recuperarse de un incidente, siendo el pilar más robusto de la Ciberresiliencia. Debe existir un procedimiento riguroso de respaldo y recuperación, que incluya pruebas periódicas.
- **Gestión de Incidentes:** Debe haber una clara distribución de roles, responsables y cadena de llamadas/escalado. La ISO/IEC 27035 establece los principios para la gestión de incidentes, que incluye fases de Planificación, Detección, Evaluación y Respuesta.
- **Entrada en Producción:** Este proceso busca minimizar el riesgo asociado a la incorporación de nuevo hardware o software. El área de seguridad debe participar de forma mandatoria para

establecer requisitos de seguridad previamente a la adquisición. Se deben planificar Planes de Contingencia y de "vuelta atrás" (roll-back) antes de trabajar en producción.

- Configuraciones e Inventario: Es crucial mantener un inventario centralizado y "vivo" de todos los elementos de red (incluyendo fabricante, modelo, versión de software, direcciones IP, aplicaciones instaladas y control de cambios). Esto facilita la identificación rápida de elementos vulnerables ante la difusión de fallos de seguridad.

El SGSI como Requisito de Resiliencia

El SGSI, regido por la familia ISO 27000, proporciona el marco estratégico y metodológico para lograr la seguridad continua (ciclo PDCA). El proceso inicia con el Análisis de Riesgos como punto de partida crucial, define los Controles a aplicar (ISO 27001/27002), y se apoya en guías de Bastionado específicas, como las Guías CIS, para asegurar la infraestructura técnica.

La correcta implementación del SGSI no solo garantiza el cumplimiento normativo (como la ISO 27001), sino que también es la única forma de conseguir que las infraestructuras de TI sean ciberresilientes, capaces de recuperarse de incidentes graves de forma elástica y confiable, gracias a la monitorización, la medición continua (ISO 27004) y la solidez de los procesos operativos